Stripe Integration
คู่มือสำหรับนักพัฒนา

ระบบ Localforyou: payments · masterPanel · Make.com · gcal-booking-api · L4U-coupon-generator
อ้างอิง Stripe API: `https://docs.stripe.com/api` · จัดทำ 13 ต.ค. 2026 จากโค้ดใน `docker_masterPanel/` (branch bas/fix/producttomonday)

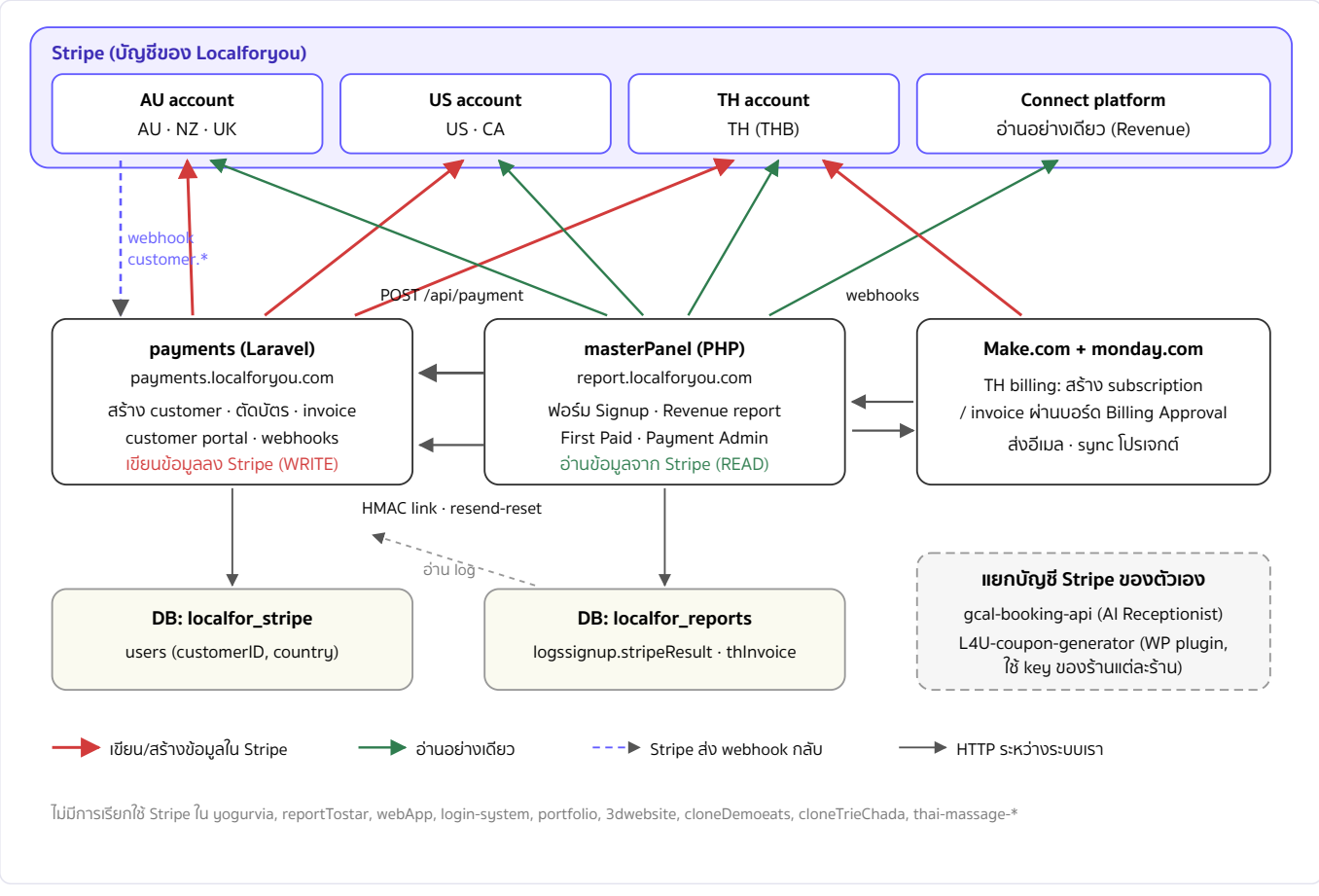
> **ขอบเขต:** เอกสารนี้อธิบายว่าโปรเจกต์ไหนเรียก Stripe API ตัวไหน ด้วย key ของบัญชีใด ข้อมูลไหลไปทางไหน และจุดไหนที่ควรแก้ **ไม่มีการใส่ secret key หรือรหัสผ่านจริงในเอกสาร** มีแค่ชื่อ env/config เท่านั้น

สารบัญ

1. ภาพรวมสถาปัตยกรรม
2. บัญชี Stripe และการเลือก key
3. payments (Laravel) ฝั่งเขียนข้อมูล
4. Flow: Signup → ตัดเงินครั้งแรก
5. Customer portal และ webhooks
6. masterPanel ฝั่งอ่านข้อมูล / รายงาน
7. TH billing ผ่าน Make.com
8. โปรเจกต์ที่ใช้ Stripe แยกบัญชี
9. ตาราง Stripe object → ไฟล์ → docs
10. ความสัมพันธ์ของข้อมูล (ID mapping)
11. ความเสี่ยงและสิ่งที่ควรแก้
12. Checklist ก่อนแก้โค้ดที่เกี่ยวกับ Stripe

1. ภาพรวมสถาปัตยกรรม

ในโฟลเดอร์ `docker_masterPanel/` มี 4 โปรเจกต์ที่เรียก Stripe API จริง โปรเจกต์อื่นไม่มีการเรียกใช้ Stripe (ตรวจด้วย grep แล้ว)



ไม่มีการเรียกใช้ Stripe ใน yogurvia, reportTostar, webApp, login-system, portfolio, 3dwebsite, cloneDemoeats, cloneTrieChada, thai-massage-*

โปรเจกต์	ภาษา / SDK	บทบาทเกี่ยวกับ Stripe
payments payments.localforyou.com	Laravel · `stripe/stripe-php` (`StripeClient`)	ตัวเดียวที่**สร้าง/แก้**ข้อมูลใน Stripe สำหรับลูกค้า L4U ได้แก่ customer, payment method, setup intent, invoice item, invoice, subscription update และ billing portal session นอกจากนี้ยังรับ webhook `customer.*` และเป็นระบบ login ของลูกค้า
masterPanel report.localforyou.com	PHP ล้วน · stripe-php (composer)	(1) ฟอร์ม Signup ฝั่งเบราว์เซอร์ POST ไปที่ payments (2) อ่านข้อมูลจาก Stripe มาทำรายงาน Revenue และคอลัมน์ First Paid (3) ลิงก์ Payment Admin แบบ HMAC เข้า payments

gcal-booking-api	Python FastAPI · `stripe`	AI Receptionist ใช้ขายนาทีโทร (PaymentIntent) บันทึกบัตร (SetupIntent) และตัดเงินอัตโนมัติแบบ off-session มี webhook ที่ตรวจลายเซ็นถูกต้อง
L4U-coupon-generator	WordPress plugin · stripe-php (legacy)	ขาย Gift Voucher บนเว็บร้าน (Amelia) ใช้ `\Stripe\Charge::create` กับ token ที่ได้จาก Stripe.js โดยใช้ key ของ**แต่ละร้าน** ซึ่งตั้งค่าในหน้า WP admin

2. บัญชี Stripe และการเลือก key

ลูกค้า L4U แบ่งตามประเทศไปยัง Stripe 3 บัญชี และมีบัญชี Connect อีกหนึ่งบัญชีที่ใช้อ่านรายได้อย่างเดียว ทั้ง payments และ masterPanel ใช้กฎการแบ่งเดียวกัน

บัญชี	ประเทศ	สกุลเงิน	payments (.env)	masterPanel (api/stripe/stripe_config.php)	Payment methods
AU	AU, NZ, UK	aud / nzd / gbp	`STRIPE_KEY` `STRIPE_KEY_TEST`	`'au'` (TZ Australia/Queensland)	card · `au_becs_debit` (AU)
US	US, CA	usd / cad	`STRIPE_KEY_US` `STRIPE_KEY_US_TEST`	`'us'`	card · `us_bank_account` (US)
TH	TH	thb	`STRIPE_KEY_TH` `STRIPE_KEY_TH_TEST`	`'th'` (TZ Asia/Bangkok)	card
Connect	—	หลายสกุล	—	`'connect'`	อ่าน balance / accounts

ฟังก์ชันที่ใช้เลือก key คือ `APIController::getStripeKeyAndCurrency()` ใน `payments/app/Http/Controllers/APIController.php` มีหลักการดังนี้

```
env == "test" ? *_TEST : live
country ∈ {NZ, AU, UK} → STRIPE_KEY(_TEST)      currency: nzd/aud/gbp
country == TH          → STRIPE_KEY_TH(_TEST)   currency: thb
อื่น ๆ (US, CA, …)      → STRIPE_KEY_US(_TEST)   currency: usd/cad (default usd)
* throw Exception ถ้า env key ตัวใดตัวหนึ่งในหกตัวว่าง
```

ฝั่ง masterPanel มี `$COUNTRY_TO_ACCOUNT` ใน `pages/tableRendering/getFirstPaidStatus.php` (และไฟล์ get* อื่น ๆ) ที่แบ่งแบบเดียวกัน **ถ้าแก้กฎฝั่งใดฝั่งหนึ่ง ต้องแก้อีกฝั่งด้วย**

> **ข้อควรระวัง:** controller บางตัวไม่ผ่าน `getStripeKeyAndCurrency()` แต่ใช้ `env("STRIPE_KEY")` (บัญชี AU) ตรง ๆ ได้แก่ `BillingPortal`, `BecsController`, `PaymentMethodController`, `getProducts/getPrice/getPriceAll` ส่วน `UpdateCard` กับ `CreateCustomer` แยกได้แค่ US กับ non-US ผลคือลูกค้า TH ที่เปิด billing portal หรืออัปเดตบัตร จะถูกส่งไปหาในบัญชี AU และหา customer ไม่เจอ (ดูหัวข้อ 11)

3. payments (Laravel) ฝั่งเขียนข้อมูล

3.1 API routes (`routes/api.php`, prefix `/api`, middleware `throttle:api`, CORS `*`)

Endpoint	Controller	Stripe calls	เรียกจาก
`POST /api/payment`	APIController@getPayment	customers.create → paymentMethods.create → setupIntents.create(confirm) → [verifyMicrodeposits] → customers.update(default PM) → invoiceItems.create ×N → invoices.create → invoices.pay · ถ้า error: customers.delete	masterPanel signup / quotation / templates / cancellation (card, direct debit)
`POST /api/invoice`	APIController@getPayment2	customers.create → invoiceItems.create ×N → invoices.create(`send_invoice`, due 3 วัน) → finalizeInvoice → sendInvoice · pinned `stripe_version 2017-08-15`	ฟอร์ม signup ที่เลือก "Invoice"
`POST /api/dev/payment` `POST /api/dev/invoice`	APIControllerDev	เหมือนข้างบนแต่เป็นโค้ดรุ่นเก่า (ไม่มี TH, ไม่มี cleanup customer)	module `mini`
`POST /api/create-customer`	APIController@createCustomer	customers.create	—

`GET /api/products`
`GET /api/price/{id}`
`POST /api/price`
	APIController	products.all(type=service) · prices.all(product) · products.retrieve (บัญชี AU เท่านั้น)	—

`POST /api/staff/resend-reset`	StaffPasswordReset@resend	ไม่เรียก Stripe · ตรวจ header `X-MP-Secret`	masterPanel หน้า Payment Password

3.2 Web routes ที่เกี่ยวกับ Stripe (`routes/web.php`)

Route	Auth	Stripe calls
`POST /webhooks?country=AU|US|TH`	ไม่มี (ไม่ตรวจลายเซ็น)	รับ event `customer.created` แล้ว upsert `users` และส่งอีเมลรหัสผ่านให้ลูกค้า (queue)
`POST /customer-update`	ไม่มี	รับ event `customer.updated` แล้ว update name/email ตาม customerID
`GET /billing`, `/portal`	login ลูกค้า	billingPortal.sessions.create → redirect
`GET/POST /updatecard`	login ลูกค้า	paymentMethods.create(card) → attach → customers.update(default)
`/direct-debit` → `POST /updatebank`	login ลูกค้า	AU BECS: paymentMethods.create → setupIntents.create(mandate) → customers.update
`/direct-debit-us` → `POST /updatebank-us`	login ลูกค้า	US ACH: paymentMethods.create → setupIntents.create → verifyMicrodeposits
`/admin-*`, `/create`, `/updatebank-admin`, `/api/get-subscription-items`, `/api/update-subscription-plan`	`mp.admin` (HMAC จาก masterPanel หรือ isAdmin)	customers.create · allPaymentMethods + detach · subscriptions.retrieve(expand price.product) · subscriptions.update(proration none)
`/customerlist`, `/attachpm`, `/detachpm`, `/test/*`	**ไม่มี**	customers.all · paymentMethods.attach/detach · tokens/sources (ทดสอบ)

4. Flow: Signup → ตัดเงินครั้งแรก

ไฟล์หลัก: `masterPanel/modules/signup/assets/js/ajaxFunction.js` ฟังก์ชัน `requestToPay()` → `payments APIController@getPayment`

1. **เบราว์เซอร์ staff** สร้าง `stripePayload`: env, country (GB→UK), payment_method (`card` / `direct` / `us_bank_account` / `invoice`), products {subscription[], add_on[]} (price IDs จาก JSON ราคา), coupon map {priceId: couponCode}, tax_rate_id, setup_fee, card / bank fields
2. `saveToDB(safePayload)` บันทึกลง `logssignup` ก่อน โดยตัดเลขบัตรให้เหลือ 4 หลักท้าย ถ้าเป็น TH จะบันทึกข้อมูลภาษีด้วย (`saveTaxToDB`)
3. ถ้าติ๊ก "Make Charge" จะ POST JSON ไปที่ `settings.url_payment.card|invoice`
4. payments: `customers.create` {name=ร้าน, email, description=ชื่อเจ้าของ}
5. `paymentMethods.create` (card / us_bank_account / au_becs_debit) → `setupIntents.create` {confirm:true, mandate_data.online{ip,user_agent}} → `customers.update` {invoice_settings.default_payment_method}
6. `invoiceItems.create` หนึ่งครั้งต่อ price (subscription + add_on) แบบ `discounts:[{coupon}]` ถ้ามี และ Setup Fee เป็น item ที่ระบุ amount เอง

7. `invoices.create` (AU ใส่ `default_tax_rates`) → `invoices.pay` {payment_method}
8. Response `{message:"Success", customer_id, invoice_id(=invoice.number)}` ถ้าเกิด error จะได้ `422 {message}` และลบ customer เปล่าทิ้ง
9. เบราว์เซอร์เรียก `stripeResToDB()` เขียน response ลง `logssignup.stripeResult` (ถ้าล้มเหลวจะขึ้นต้นด้วย `"Ajax Fail : "`) ถ้าเป็น TH จะเรียก `invoiceIDToDB` ด้วย จากนั้นอัปโหลดเอกสาร ส่งอีเมลผ่าน Make.com และส่งต่อไปยัง monday

> **Subscription ไม่ได้ถูกสร้างใน repo นี้** ไม่พบการเรียก `subscriptions.create` ในโค้ดเลย flow นี้สร้างแค่ customer และ invoice แรก ส่วน subscription (รอบบิลถัดไป) ถูกสร้างภายนอก เช่นผ่าน Make.com หรือ Stripe Dashboard ใน repo นี้มีแค่ `subscriptions.retrieve/update` (Payment Admin) กับ `subscriptions.all` (รายงาน MRR)

> **ตัวตรวจจับ signup ที่ค้าง:** `api/signup/checkMissingStripe.php` (cron รายชั่วโมง) หาแถว `logssignup` ที่ `stripeResult` ว่างนานกว่า 30 นาที (ย้อนหลัง 7 วัน) แล้วแจ้งทีม IT (teamID 5) ด้วย type `signup_no_stripe`

5. Customer portal และ webhooks

```
Stripe (customer.created) ──POST /webhooks?country=XX──▶ payments
   └─ User::updateOrCreate(email){customerID, name, password(hash), key, country}
   └─ Mail::queue(CustomerCredentialsMail) + NewCustomerAdminMail ×2
Stripe (customer.updated) ──POST /customer-update──▶ update name/email by customerID

ลูกค้า login (payments users) ─▶ /billing ─▶ billingPortal.sessions.create(customer) ─▶ Stripe-hosted portal
                               ─▶ /updatecard | /direct-debit | /direct-debit-us
```

ต้องตั้ง endpoint ใน Stripe Dashboard ของแต่ละบัญชีให้ส่ง query `?country=` ให้ถูกต้อง (ค่าที่รับได้คือ AU, US, TH และถ้าไม่ระบุจะเป็น AU)

Payment Admin (เข้าจาก masterPanel): masterPanel สร้างลิงก์ `?userID=&exp=&sig=HMAC_SHA256("userID|exp", MASTERPANEL_RESET_SECRET)` แล้ว middleware `MasterPanelAdmin` ตรวจลายเซ็นและวันหมดอายุ จากนั้นสร้าง session `mp_admin` และ redirect ไปยัง URL ที่ไม่มี query โดยค่า secret ต้องตรงกันทั้งสองฝั่ง (`docker-compose.yml` / `payments_secret.txt` ↔ `payments/.env`)

6. masterPanel ฝั่งอ่านข้อมูล / รายงาน

ไฟล์	Stripe calls	ใช้ที่
`api/stripe/getData.php`	balance.retrieve · payouts.all · balanceTransactions.all · charges.all(expand customer) · subscriptions.all (MRR) · customers.all / accounts.all (Connect)	`pages/reportRevenue.php`
`api/stripe/cache_stripe_data.php`, `refreshCache.php`	เหมือน getData แต่เขียนลง `api/stripe/cache/{acct}_{period}.json`	CLI/cron + ปุ่ม refresh
`api/stripe/getTransactions.php`	balanceTransactions.all	reportRevenue (ตารางธุรกรรม)
`compareData / benchmark_expand / test_payout / getData_cached`	สคริปต์ทดสอบ/เทียบข้อมูล	dev เท่านั้น
`pages/tableRendering/getFirstPaidStatus.php`	invoices.all(customer, limit) → สถานะใบแรก	คอลัมน์ First Paid ใน Signup Logs / View Logs
`getInvoiceDetail / getSubInvoices / getPaymentHistory / getPaymentMethod.php`	invoices.retrieve/all · customers.retrieve · paymentMethods.all	modal ใน `pages/partials/firstPaidColumn.php`
`api/revenue/getSummary.php`	ไม่เรียก Stripe ตรง ๆ แต่รวมข้อมูล stripe_au/us/th กับ Yelp/SMS (อัตราแลกเปลี่ยน hardcode)	Revenue summary

Cache TTL ของ getData: 7/28 วัน = 5 นาที, 90/180 วัน = 30 นาที, 365 วัน/alltime = 1 ชม. ส่วน First Paid ใช้ 7 วันสำหรับ invoice ที่ปิดแล้ว (paid/void/uncollectible) และ 15 นาทีสำหรับ open/draft โฟลเดอร์ cache อยู่ที่ `api/stripe/cache/{first_paid,sub_paid,payment_history,payment_method}`

การหา customer id ของ signup: ดึงจาก `logssignup.stripeResult` (JSON response ของ payments) หรือ `dataStripe` ชื่อ key เปลี่ยนไปหลายแบบตามช่วงเวลา และบางแถวเป็น string ล้วน เช่น `"Test Mode – No Charge"` ดังนั้นต้อง `json_decode` แล้วตรวจว่าเป็น array ก่อนอ่าน

7. TH billing ผ่าน Make.com

ใบแจ้งหนี้และใบเสร็จของ TH ใช้ระบบภายในของ masterPanel (`thInvoice`, `thCustomer`, `thApoMonday`) ร่วมกับ Make.com และ monday.com

- `api/invoice/createSubTH.php` รับ webhook จาก Make.com เมื่อบอร์ด monday กด "Charge Customer" แล้วสร้างรอบบิลและส่ง webhook กลับไปส่งอีเมล
- `api/invoice/createInvoiceTH.php` รับ amount (ราคารวม VAT) จาก Make.com แล้วออก invoice
- ทุกการออกบิลหรือสร้าง subscription ของ TH ต้องผ่านบอร์ด Billing Approval ก่อน และใน Make.com ให้แยกเส้นทางด้วย **subscription ID ไม่ใช่ country** เส้นทางเก่าให้ disable แทนการลบ
- สูตรภาษีเป็นของฝ่ายบัญชี ห้ามแก้เองในโค้ด
- `api/invoice/migrate_stripe_invoices.php` เป็นสคริปต์ที่รันครั้งเดียว ใช้ย้าย invoice จากภาพ Stripe เข้า `thInvoice`

8. โปรเจกต์ที่ใช้ Stripe แยกบัญชี

8.1 gcal-booking-api (AI Receptionist) — `app/main.py`

Endpoint	Stripe
`GET /api/stripe/config`	ส่ง publishable key และแพ็กเกจนาที (`MINUTES_PACKAGES`)
`POST /api/stripe/create-payment-intent`	PaymentIntent.create (usd) → client_secret → Stripe.js confirm
`POST /api/stripe/setup-intent`	Customer.create (ถ้ายังไม่มี) → SetupIntent.create สำหรับบันทึกบัตรเพื่อใช้ auto-recharge
`POST /api/stripe/payment-method`	PaymentMethod.retrieve · detach ใบเก่า → บันทึก `shop.stripe_payment_method_id`
auto-recharge (ภายใน)	PaymentIntent.create{off_session, confirm} เมื่อนาทีเหลือน้อย
`POST /api/stripe/webhook`	`stripe.Webhook.construct_event` + `STRIPE_WEBHOOK_SECRET` (ตรวจลายเซ็นถูกต้อง) · `payment_intent.succeeded / payment_failed`

Env ที่ใช้: `STRIPE_SECRET_KEY` , `STRIPE_PUBLISHABLE_KEY` , `STRIPE_WEBHOOK_SECRET` ดูรายละเอียดได้ที่ `STRIPE_SETUP.md` ในโปรเจกต์ (ในเครื่องมี 2 โฟลเดอร์คือ `gcal-booking-api-main` และ `gcal-booking-api-main 2` โดยรุ่น "2" ใหม่กว่าและมี SetupIntent/auto-recharge)

8.2 L4U-coupon-generator (WP plugin "LFY | Amelia Coupon Generator")

หน้าเว็บร้านใช้ Stripe.js เพื่อได้ `stripeToken` แล้วฝั่ง server เรียก `\Stripe\Charge::create` (Charges API ซึ่งเป็น **legacy**) โดยใช้ key จาก `get_option('stripe_secret_key')` ของร้านนั้น ๆ เมื่อสำเร็จจะสร้างคูปองใน Amelia ส่งอีเมล voucher และส่ง log ไปที่ Make.com ระบบนี้ไม่เชื่อมกับ payments หรือ masterPanel

9. ตาราง Stripe object → ไฟล์ → docs

Object	Methods ที่ใช้	ใช้ใน	docs.stripe.com/api/...
Customers	create, update, retrieve, all, delete	payments, masterPanel (read), gcal	`/customers`
PaymentMethods	create, attach, detach, all	payments, gcal	`/payment_methods`
SetupIntents	create(confirm), verifyMicrodeposits	payments, gcal	`/setup_intents`
PaymentIntents	create	gcal	`/payment_intents`
Invoice Items	create (price / amount, discounts)	payments	`/invoiceitems`
Invoices	create, finalize, pay, send, retrieve, all	payments, masterPanel	`/invoices`
Subscriptions	retrieve, update, all	payments (admin), masterPanel (MRR)	`/subscriptions`
Products / Prices	all, retrieve	payments	`/products` , `/prices`
Customer Portal	billingPortal.sessions.create	payments	`/customer_portal/sessions`
Balance / Balance Tx	retrieve, all	masterPanel	`/balance` , `/balance_transactions`
Payouts	all	masterPanel	`/payouts`
Charges	all (อ่าน), create (legacy)	masterPanel, coupon plugin	`/charges`
Accounts (Connect)	all	masterPanel	`/accounts`
Webhooks / Events	รับ customer.*, payment_intent.*	payments, gcal	`/events` · `/webhook_endpoints`

หมายเหตุ: list ทุกตัวใช้ `limit 100` + `autoPagingIterator()` ส่วนจำนวนเงินจาก Stripe เป็นหน่วยย่อยสุด (cents/สตางค์) จึงต้องหาร 100 · `getPayment` ส่ง `setup_fee` ไปตรง ๆ แต่ `getPayment2` คูณ 100 ให้ ฝั่งที่เรียกจึงต้องส่งหน่วยให้ตรงกับ endpoint

10. ความสัมพันธ์ของข้อมูล (ID mapping)

ที่เก็บ	ฟิลด์	ความหมาย
`localfor_reports.logssignup`	`stripeResult` , `dataStripe` , `countryCode` , `test`	response ของ payments (customer_id, invoice number) · ประเทศใช้เลือกบัญชี Stripe

ฟอร์ม signup (hidden)	`customerStripeID` / `customerStripeIDUSA`	`cus_…` ที่ส่งต่อไปยังอีเมลและ monday
`localfor_stripe.users` (payments)	`customerID`, `email`, `country`, `isAdmin`	บัญชี login ของลูกค้า ผูกกับ `cus_…`
`localfor_stripe.password_reset_logs`	—	masterPanel อ่านผ่าน `assets/db/initDBstripe.php`
upgrade-downgrade form	`stripeId`, `mondayProjectId`	เชื่อมลูกค้า Stripe กับโปรเจกต์ monday
gcal DB	`shop.stripe_customer_id`, `stripe_payment_method_id`, `Payment.stripe_payment_intent_id`	คนละบัญชี Stripe กับ L4U

11. ความเสี่ยงและสิ่งที่ควรแก้

เรียงตามความรุนแรง ทุกข้อตรวจจากโค้ดจริงแล้ว แต่**ยังไม่ได้ทดสอบโจมตีจริง**

HIGH **Secret key อยู่ในโค้ด** พบ `sk_…` hardcode ใน `payments/…/CustomerList.php`, `BecsController::createCustomer`, `APIControllerDev.php` และใน comment ของ `APIController.php` ส่วนรหัส DB ของ `localfor_stripe` อยู่ใน `masterPanel/assets/db/initDBstripe.php` ซึ่งถูก commit ใน git → ควร **rotate key/รหัส** แล้วย้ายไปไว้ใน env (สำหรับ `stripe_config.php` ไม่ได้ track ใน git ซึ่งถูกต้องแล้ว)

HIGH **Webhook ไม่ตรวจลายเซ็น** ทั้ง `/webhooks` และ `/customer-update` ทำให้ใครก็ POST ได้ ถ้ายิงเข้า `/customer-update` ด้วย customerID ของคนอื่นพร้อมอีเมลของผู้โจมตี แล้วใช้ "forgot password" ก็จะ**ยึดบัญชีลูกค้าได้** → ใช้ `\Stripe\Webhook::constructEvent($payload, $sigHeader, $whsec)` แยก secret ต่อบัญชี (ดูตัวอย่างใน gcal)

HIGH **`masterPanel/api/stripe/*.php` ไม่มีการตรวจ session** (ไม่มี `session_start` และไม่มี .htaccess) ทำให้ใครก็เรียก `getData.php?account=au` แล้วเห็นยอดขาย, balance, ชื่อและอีเมลของ top customers ได้ และยังสั่ง `refreshCache` ซ้ำ ๆ จนโดน rate limit ของ Stripe ได้ → ใส่ guard `$_SESSION['id']` แบบเดียวกับ `getFirstPaidStatus.php` และกันสคริปต์ทดสอบไม่ให้เข้าจากเว็บ

HIGH **Route ไม่มี auth ใน payments** ได้แก่ `/customerlist`, `/attachpm`, `/detachpm`, `/test/*` (รวมถึง `/test/create-admin`) และ `/api/payment` ที่ CORS `*` และไม่มี auth ทำให้ถูกใช้ทำ **card testing** ได้ → ปิด route ทดสอบ, ใส่ `mp.admin` และ origin allowlist / token

MED **เลขบัตรดิบวิ่งผ่าน server ของเรา** (`paymentMethods.create` ด้วย card number/CVC ใน `getPayment` และ `UpdateCard`) ทำให้ต้องอยู่ในขอบเขต PCI SAQ D และ Stripe ปิดการส่งบัตรดิบผ่าน API เป็นค่าเริ่มต้น → ควรย้ายไปใช้ Stripe Elements / Payment Element + SetupIntent client_secret

MED **Mandate data ปลอม** ฟอร์ม signup ส่ง `ip_address "58.8.159.115"` และ user_agent แบบ hardcode ทำให้ mandate ของ BECS/ACH ไม่ใช่ของลูกค้าจริง ซึ่งอาจมีปัญหาตอนเกิด dispute → ให้ใช้ `$request->ip()` และ header ที่ฝั่ง server

MED `verifyMicrodeposits(['amounts'=>[32,45]])` เป็นค่าสำหรับ test mode แต่ถูกเรียกใน live ด้วย (`getPayment`, `ACHController`) → live ต้องให้ลูกค้ากรอกยอดเองหรือใช้ Financial Connections

MED **เลือกบัญชีผิดสำหรับ TH/US** (ดูหัวข้อ 2) ได้แก่ BillingPortal, BECS, PaymentMethodController และ products/prices ที่ใช้บัญชี AU อย่างเดียว ส่วน webhook รับ `?country=` ได้แค่ AU/US/TH ถ้าเป็นค่าอื่นจะตอบ 400

MED `users.key` **เก็บรหัสผ่านแบบ plaintext** และสุ่มด้วย `rand()` 10 ตัวอักษร A–Z → เลิกเก็บ key แล้วส่งลิงก์ตั้งรหัสแทน

LOW `var_dump($array)` ใน `attachWithSetupIntent` พ่นข้อมูลออกไปใน response · `getPayment2` pin `stripe_version 2017-08-15` ต่างจาก endpoint อื่น · `APIControllerDev` เป็นโค้ดซ้ำที่ไม่มี cleanup customer · `getPayment` ส่งคืน 500 ระหว่างทางโดยไม่ลบ customer เปล่า (ใน try ด้านใน) · อัตราแลกเปลี่ยนใน `getSummary.php` เป็นค่า hardcode · Charges API ใน coupon plugin เป็น legacy

12. Checklist ก่อนแก้โค้ดที่เกี่ยวกับ Stripe

- ทดสอบด้วย `env:"test"` และ `*_TEST` keys เสมอ บัตรทดสอบ `4242 4242 4242 4242` และ BECS ทดสอบ BSB `000000` / acct `000123456`
- ถ้าแก้กฎประเทศ → บัญชี ต้องแก้ทั้ง `getStripeKeyAndCurrency` และ `$COUNTRY_TO_ACCOUNT` ในทุกไฟล์ `pages/tableRendering/get*.php`
- ถ้าเปลี่ยนรูปแบบ response ของ `/api/payment` ต้องแก้ตัวอ่าน customer id ใน masterPanel (First Paid, AI logs) และ `stripeResToDB`
- ถ้าแก้ schema ของ `logssignup` / `thInvoice` ต้องมีไฟล์ migration SQL + rollback ใน `docs/migrations/` เพราะ production ที่ report.localforyou.com ใช้ DB ตัวจริง
- TH: ห้ามข้ามบอร์ด Billing Approval · Make.com ใช้ disable ไม่ใช่ลบ
- ห้าม commit key ใหม่ ให้เก็บใน `payments/.env` / `stripe_config.php` (ไม่ track) และ rotate ทันทีถ้าหลุด